

# Mémo OWASP Top 10:2025

TP 5 · Analyser un test web



Ce mémo sert à rattacher un constat à une catégorie du Top 10 sans connaissance externe.  
Utilise le code et la description ensemble.



## A01 Broken Access Control

Code de réponse : a01

Définition courte : Accès à l'objet ou à la fonction d'un autre compte sans contrôle suffisant, y compris une SSRF qui franchit une frontière de confiance.

Repère : une réponse 200 ou une action autorisée sur un identifiant appartenant à un autre utilisateur, ou une requête côté serveur vers une ressource interne non prévue.



## A02 Security Misconfiguration

Code de réponse : a02

Définition courte : Configuration trop bavarde, trop permissive ou durcissement absent.

Repère : en-tête de framework, stockage public, mode debug ou politique absente exposée sans besoin.



## A03 Software Supply Chain Failures

Code de réponse : a03

Définition courte : Dépendances, composants ou processus d'approvisionnement non vérifiés.

Repère : bibliothèque compromise, source non fiable ou mise à jour non contrôlée.



## A04 Cryptographic Failures

Code de réponse : a04

Définition courte : Protection cryptographique absente, obsolète ou mal appliquée.

Repère : données sensibles sans chiffrement ou algorithme inadapté.



## A05 Injection

Code de réponse : a05

Définition courte : Donnée utilisateur interprétée comme commande, requête ou expression.

Repère : SQL, OS, template ou moteur de recherche modifié par une saisie.



## A06 Insecure Design

Code de réponse : a06

Définition courte : Mécanisme absent du design, même si le code suit la spécification.

Repère : aucun garde-fou prévu contre un abus métier attendu.



## A07 Authentication Failures

Code de réponse : a07

Définition courte : Faiblesses d'authentification ou de cycle de session.

Repère : énumération de comptes, fixation de session, rotation absente, logout incomplet.



## A08 Software or Data Integrity Failures

Code de réponse : a08

Définition courte : Code, mise à jour ou données modifiés sans vérification d'intégrité.

Repère : pipeline ou import accepté sans signature ni contrôle d'origine.



## A09 Security Logging & Alerting Failures

Code de réponse : a09

Définition courte : Journalisation, détection ou alerte insuffisantes.

Repère : événement critique non tracé, non corrélé ou non remonté.



## A10 Mishandling of Exceptional Conditions

Code de réponse : a10

Définition courte : Erreurs, états anormaux ou reprises hasardeuses mal gérés.

Repère : exception bavarde, fail-open, débordement de taille ou reprise dangereuse après erreur.



### Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite.